

SOC 2 Readiness Assessment Report :

BrightLoop Analytics

Date: 2026-07-26

Assessor: GRC Analyst

Report Version: 1.0

Assessment Type: SOC 2 Readiness Assessment

Linked Workbook: SOC2-Readiness-Controls-Tracker-BrightLoop.xlsx

Linked Scoping Document: SOC2-Scoping-Document-BrightLoop-Analytics.docx

Executive Summary

BrightLoop Analytics has a strong technical foundation but is not yet ready to begin a SOC 2 examination. The company already has important security protections in place, particularly around controlling access to its systems, but several important security processes are informal, inconsistently performed, or not yet formally documented. The most significant gaps involve the absence of a formal incident response process, the lack of a structured vendor risk program, and the absence of a mature, documented approach to identifying and managing security risks. These gaps should be addressed before BrightLoop begins its formal audit process. BrightLoop should initially pursue a focused SOC 2 examination covering the Security criteria rather than expanding the scope unnecessarily. After the highest-priority gaps are remediated, the company should operate its controls consistently and collect evidence over a six-month observation period. Based on the current business context, a direct Type II approach is recommended because it provides evidence that controls operated consistently over time and better supports enterprise customer requirements.

1. Assessment Purpose

The purpose of this assessment was to evaluate BrightLoop Analytics' readiness to pursue a SOC 2 examination.

The assessment evaluated:

- The organization's current security governance practices
- Risk management processes
- Access control activities
- Security monitoring and incident response capabilities
- Change management practices
- Vendor risk management

- Control documentation and ownership
- Evidence collection readiness

The assessment was performed against the applicable SOC 2 Common Criteria and focused on whether BrightLoop has the policies, processes, controls, and evidence necessary to support a future examination.

2. Company and Business Context

BrightLoop Analytics is a 120-employee B2B SaaS company providing a marketing analytics platform to business customers.

The platform is hosted on AWS and the organization uses Microsoft 365 for business operations and collaboration.

BrightLoop is pursuing SOC 2 readiness to support pending enterprise customer opportunities. The organization has not previously operated a formal compliance program.

The assessment therefore considered both:

1. Existing technical security capabilities; and
2. The maturity of the governance, documentation, monitoring, and evidence processes required to demonstrate that those capabilities operate consistently.

3. Assessment Scope

Trust Services Criteria

In Scope:

- Security / Common Criteria

Out of Scope:

- Availability
- Processing Integrity
- Confidentiality
- Privacy

The initial scope is intentionally focused on Security because this criterion is most directly aligned with BrightLoop's current enterprise customer requirements and security assurance objectives.

Additional criteria may be considered in future audit cycles if customer contracts, business requirements, or management commitments change.

System Boundary

The assessment considered the following systems, processes, and personnel:

- AWS production infrastructure
- Production application environment
- Production customer database
- Identity and access management systems
- Microsoft 365 services relevant to security and business operations
- Customer support platform
- CI/CD pipeline used for production deployments
- Personnel responsible for developing, operating, securing, and supporting the production environment
- Security, access management, incident response, change management, and vendor management processes supporting the production environment

4. Assessment Methodology

The assessment evaluated each of the nine SOC 2 Common Criteria areas.

The assessment considered:

- Current documented policies and procedures
- Existing technical and operational controls
- Control ownership
- Control frequency
- Evidence availability
- Consistency of control operation
- Identified gaps and associated business risk

Each identified gap was assigned a severity based on its potential effect on BrightLoop's ability to demonstrate effective control operation and support a future SOC 2 examination.

5. Gap Summary

The current assessment identified gaps across governance, risk management, control documentation, access management, incident response, change management, and vendor risk management.

Severity	Open	In Progress	Resolved	Total
Critical	0	0	0	0
High	22	5	0	27
Medium	8	2	0	10
Low	0	0	0	0

Overall Readiness Status: Not Ready for Examination

Note: Final gap counts should be updated directly from the Dashboard sheet in the SOC 2 Readiness & Controls Tracker immediately before management approval of this report.

6. Key Findings

6.1 Governance and Control Ownership

BrightLoop has not previously operated a formal compliance program.

Although employees perform security-related activities, security responsibilities, control ownership, evidence requirements, and management oversight are not consistently documented.

Business Impact: The organization may have effective activities in practice but may be unable to demonstrate clear accountability and consistent oversight to an external auditor.

Recommended Action: Establish formal security governance, assign control owners, and create a documented control library.

6.2 Risk Management

BrightLoop does not currently have a mature, formalized information security risk assessment process.

Risks are not consistently documented, scored, assigned, and tracked through a formal risk register and treatment process.

Business Impact: Management may lack a consistent method for identifying and prioritizing security risks.

Recommended Action: Implement a formal risk assessment methodology, risk register, and risk treatment process.

6.3 Access Management

BrightLoop already has strong technical access controls.

However, user access reviews are performed inconsistently and do not follow a fixed recurring schedule.

Business Impact: BrightLoop may be unable to demonstrate that access remains appropriate over time.

Recommended Action: Establish quarterly access reviews with documented approval, review evidence, and remediation tracking.

6.4 Incident Response

BrightLoop does not currently have a formal, approved, and tested Incident Response Plan.

Informal response activities may exist, but responsibilities, escalation procedures, communications, and recovery activities have not been documented and tested as a formal process.

Business Impact: A security incident could result in inconsistent response and delayed decision-making.

Recommended Action: Develop and approve an Incident Response Plan and conduct a tabletop exercise.

6.5 Vendor Risk Management

BrightLoop does not currently have a formal vendor risk management program.

The organization relies on important third-party services, including AWS and Microsoft 365, but vendor risk classification, security assessment, and ongoing review processes are not formally established.

Business Impact: Risks introduced by important service providers may not be consistently identified or monitored.

Recommended Action: Create a vendor inventory, establish risk tiers, perform security assessments, and conduct periodic reviews of higher-risk vendors.

7. Top Priority Remediation Items

Priority 1 — Formal Incident Response Program

Related Criteria: CC7.3, CC7.4, CC7.5

Owner: CISO

Severity: High

Develop, approve, and communicate a formal Incident Response Plan covering:

- Incident identification
- Severity classification
- Escalation
- Internal and external communication
- Investigation
- Containment
- Recovery
- Post-incident review

The plan should be tested through a tabletop exercise.

Priority 2 — Vendor Risk Management Program

Related Criteria: CC9.2

Owner: GRC Analyst

Severity: High

Implement:

- Vendor inventory
- Vendor risk classification
- Security assessment process
- Contract security requirements
- Periodic vendor reviews
- Collection of relevant third-party assurance reports

Priority 3 — Formal Information Security Risk Assessment

Related Criteria: CC3.1, CC3.2, CC9.1

Owner: GRC Analyst

Severity: High

Create a formal risk management process that identifies, assesses, prioritizes, treats, and tracks information security risks.

Priority 4 — Formal Governance and Control Ownership

Related Criteria: CC1.1, CC1.2, CC1.3, CC5.1

Owner: CISO / GRC Analyst

Severity: High

Establish:

- Security governance responsibilities
- Control ownership
- Management review
- Control documentation
- Evidence requirements

Priority 5 — Consistent Access Reviews

Related Criteria: CC6.3

Owner: IT Director

Severity: Medium

Establish a formal quarterly review process for access to in-scope systems.

Each review should include:

- User access listing
- Reviewer identity
- Approval or removal decisions
- Evidence of completed remediation

8. Recommended Remediation Sequence

Phase	Activity	Target
Phase 1	Establish governance and assign control owners	First 30 days
Phase 2	Implement risk assessment and vendor risk programs	Days 30–60
Phase 3	Complete Incident Response Plan and tabletop exercise	Days 30–60
Phase 4	Formalize change management and evidence processes	Days 45–75
Phase 5	Validate control operation and evidence readiness	Days 60–90
Phase 6	Begin Type II observation period	After remediation

9. Recommended Path Forward

Recommendation

Proceed directly to SOC 2 Type II after remediation.

BrightLoop should first complete the highest-priority remediation activities and establish the required controls.

Once the controls are implemented, the organization should begin a minimum six-month observation period during which control activities are performed consistently and supporting evidence is collected.

Justification

A Type II examination provides evidence that controls operated effectively over a period of time rather than only demonstrating that controls existed on a single date.

Because BrightLoop is pursuing SOC 2 to support enterprise customer opportunities and the assessment scenario includes a six-month observation requirement, pursuing Type II directly is more efficient than completing a separate Type I examination first.

A Type I examination may be considered if a specific customer requires an earlier point-in-time report, but it should not be pursued solely as a substitute for building sustainable control operations.

10. Evidence Readiness

BrightLoop should begin collecting evidence as soon as controls become operational.

Priority evidence areas include:

Control Area	Evidence
Access Management	Quarterly access review records
MFA	Identity provider configuration and enrollment reports
Offboarding	Account disablement records
Security Monitoring	Monitoring review records and security event evidence
Change Management	Approved change tickets and testing records
Risk Management	Risk register and treatment updates
Vendor Risk	Vendor inventory, assessments, and third-party assurance reports
Incident Response	Approved plan, tabletop exercise evidence, and incident records

Evidence should be collected throughout the observation period rather than reconstructed at the end.

11. Overall Readiness Assessment

Current Status: NOT READY FOR EXAMINATION

BrightLoop has a solid foundation for pursuing SOC 2, particularly because important technical security controls are already in place.

However, the organization currently requires additional maturity in:

- Governance
- Risk management
- Control ownership
- Incident response
- Vendor risk management
- Access review consistency
- Control monitoring
- Evidence management

The identified gaps are remediable and do not indicate that BrightLoop must redesign its entire security environment.

The primary requirement is to formalize existing responsibilities and processes, establish missing governance activities, and demonstrate that controls operate consistently over time.

12. Conclusion

BrightLoop Analytics is not currently ready to begin a SOC 2 examination, but it is well positioned to become ready through a focused remediation program.

The most important actions are to establish formal security governance, implement a structured risk and vendor management program, formalize and test incident response, and create consistent evidence collection processes.

Following remediation, BrightLoop should begin a six-month Type II observation period.

Based on the current assessment, the organization should pursue a focused Security-only SOC 2 scope and avoid adding additional Trust Services Criteria without a clear business or contractual requirement.

If management completes the remediation plan and maintains consistent evidence collection throughout the observation period, BrightLoop should be positioned to pursue a SOC 2 Type II examination.

Approval

Prepared By: _____Aryan Neupane_____

Title: GRC Analyst

Signature: _____Aryan_____

Date: __07-26-2026_____

Approved By: _____

Title: CISO / Executive Approver

Signature: _____

Date: _____

Document Control

Version	Date	Description	Author	Approver
1.0	2026-07-26	Initial SOC 2 Readiness Assessment Report	GRC Analyst	CISO / Executive Management